

TP1 : Analyse de malwares

SEC102 : Analyse de malwares

Auteur : Anthony Dessiatnikoff

Exercice 1 : Analyse statique d'un fichier ISO

Vous êtes analyste SOC et vous devez analyser un fichier reçu par mail par votre collègue Jonathan. Vous savez qu'il est sur un poste Windows 10. Le fichier a malheureusement été ouvert par Jonathan. Il faut donc comprendre ce qu'il s'est passé et si le poste a été compromis.

- 1) Récupérer le fichier « USO_Documents.iso » sur le moodle du CNAM
- 2) Un fichier ISO est une archive donc vous pouvez lister son contenu (comme un fichier ZIP).
Que contient ce fichier ISO ?
- 3) Extraire le contenu. Il va falloir analyser les 2 fichiers présents. Commencer par le premier qui a 2 extensions. Sachant que le fichier doit être ouvert sous Windows, quel est le nom qui sera affiché dans l'explorateur de fichiers (par défaut) ?

1.1. Premier fichier

- 4) Pour analyser ce fichier, installer Inkpaser : `pip install LnkParse3`
- 5) Exécuter Inkpaser pour afficher la commande exécutée par le fichier. Que fait cette commande ? Pour plus de facilité, la décomposer en plusieurs commandes successives.
- 6) Aller sur <https://lolbas-project.github.io/> et trouver pourquoi PrintBrm.exe est utilisé.

1.2. Deuxième fichier

- 1) Lister et décompresser le fichier ZIP. Quelles sont les extensions de ces fichiers décompressés ?
- 2) Pourquoi une des 2 extensions n'est pas connue ? Quel est le type du fichier ?
- 3) Quelle est la technique utilisée ici pour échapper à des détecteurs (antivirus / EDR) ? Indice : observer le fichier XML.
- 4) Télécharger la dernière version de Ghidra et le décompresser :
<https://github.com/NationalSecurityAgency/ghidra/releases>
- 5) Installer le JDK (Java Development Kit) et JRE (Java Runtime Environment) :

```
# apt-get install openjdk-17-jdk openjdk-17-jre
```
- 6) Démarrer Ghidra en se positionnant dans le répertoire de Ghidra (./ghidra_11.2.1_PUBLIC/) puis taper :

```
./ghidraRun
```
- 7) Créer un nouveau projet et **importer** le fichier exécutable à analyser.
- 8) Afficher la fonction « _main ». Le pseudo-code (sur la droite) permet de trouver l'adresse IP et le port de l'attaquant car on remarque que la victime se connecte sur un port TCP de l'attaquant. Indice : le numéro de port est présent en argument de la fonction htons(). Quelle est l'adresse IP et le numéro de port de connexion vers l'attaquant ?
- 9) En sachant que le fichier LNK a bien été cliqué par l'utilisateur Jonathan, est-ce que le poste a été compromis ? Si oui, à quoi a pu avoir accès le pirate ?

Exercice 2 : Analyse HTML

- 1) Récupérer le fichier HTML « exercice2.html » sur le moodle CNAM.
- 2) Un fichier HTML est un fichier texte donc vous pouvez l'ouvrir avec un éditeur de texte tel que Gedit, Nano ou Emacs.
- 3) Comprendre les premières lignes de Javascript (notamment la ligne 18 qui semble étrange).
- 4) Une chaîne de caractères semble être décodée avec la fonction `fromHex` (définie au-dessus). Ensuite, `eval` exécute le code. La chaîne de caractères contient donc du code Javascript une fois décodée.
- 5) A première vue (les premiers octets commencent par 6 ce qui correspond aux minuscules), il s'agit simplement de code ASCII donc trouver un moyen de décoder la chaîne en ASCII par une simple commande Linux.
- 6) Que fait ce code selon vous ?

Exercice 3 : Analyse PDF

- 1) Récupérer le fichier PDF « exercice3.pdf » sur le moodle CNAM.
- 2) Utiliser « `pdfid` » et « `strings` » sur ce fichier pour comprendre ce qu'il contient.
- 3) Des données sont chiffrées mais quel est l'algorithme de chiffrement utilisé ?
- 4) Pour retrouver les données chiffrées, vous pouvez essayer de cracker le mot de passe avec l'outil John The Ripper (par défaut dans Kali). Il faut d'abord créer un fichier lisible par John :

```
pdf2john fichier.pdf > mdp_pdf.txt
```

- 5) Ensuite, démarrer John avec ce fichier en argument :

```
john mdp_pdf.txt
```

- 6) Quel est le mot de passe trouvé ?